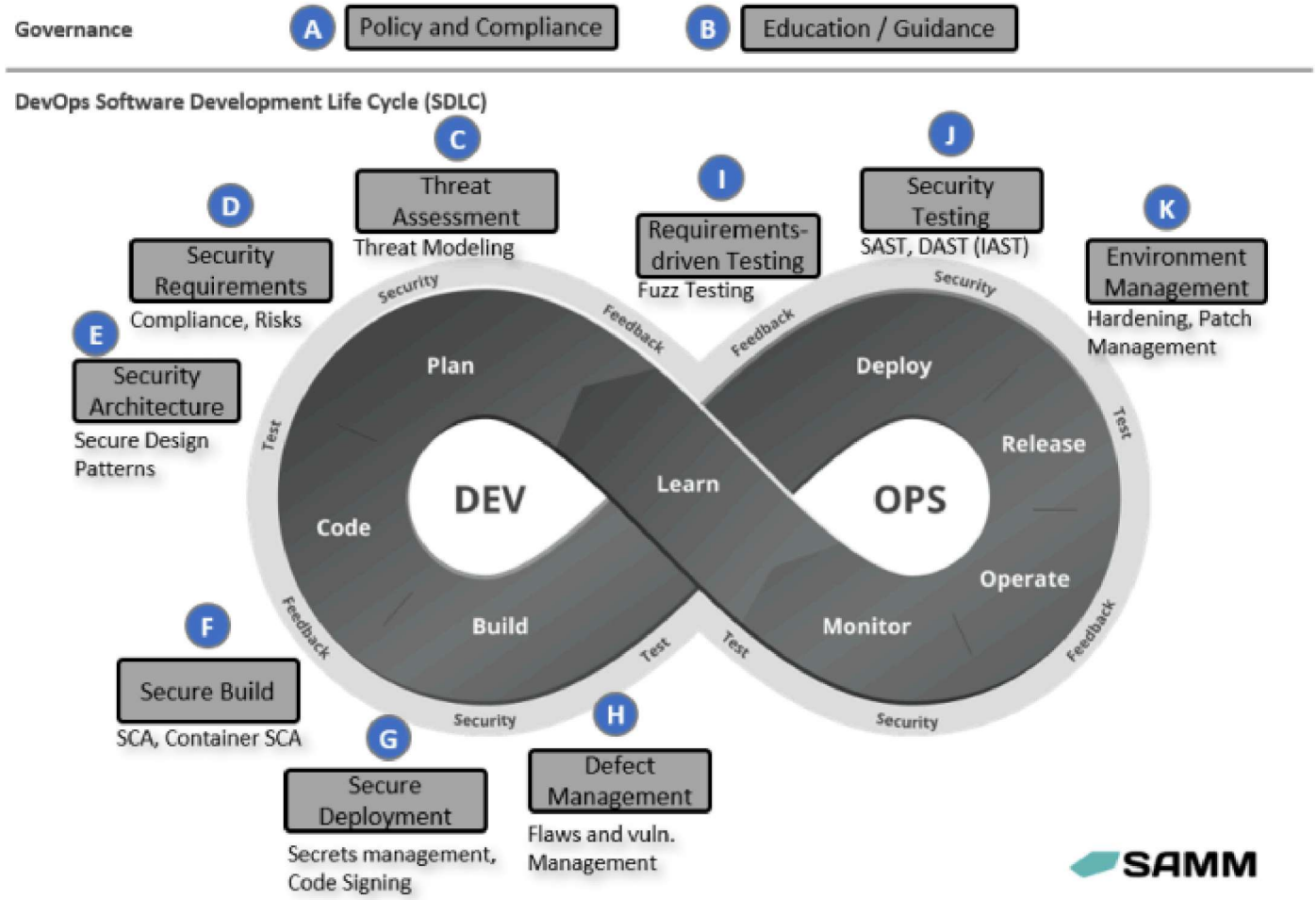
Assurance de la sécurité dans un cycle de développement applicatif (SSDLC)

L'intégration de **pratiques de sécurité** dans le cycle de développement applicatif permet de diminuer considérablement le risque de déployer une application vulnérable en production. Elle permet également d'identifier les problèmes de sécurité en amont et d'en diminuer les coûts de résolution.

Vue d'ensemble des pratiques de sécurité chez iA :



Chaque pratique identifiée ci-dessus est reliée à l'une ou plusieurs phases du cycle de développement DevOps. Elles contiennent des activités de sécurité à accomplir. Des outils technologiques sont aussi disponibles afin d'apporter l'efficience et l'automatisation nécessaires aux équipes.

Ce modèle d'iA est basé sur le modèle de référence OWASP SAMM. Pour en savoir plus, cliquez ici (https://owaspsamm.org/model/).

Mise en place

Quelles pratiques sont plus importantes et/ou prioritaires ?

Elles sont toutes complémentaires afin d'assurer la sécurité d'une solution applicative. La plupart des équipes ont déjà mis en place, souvent indirectement, des activités relatives à chacune de ces pratiques de sécurité. L'objectif est plutôt de s'assurer d'atteindre un certain niveau de maturité pour chacune, et ce, en fonction du risque de sécurité et des requis de conformités préalablement analysés pour la solution développée.

Comment intégrer/améliorer une pratique de sécurité ?

D'abord, il est recommandé de demander conseil auprès du conseiller en sécurité associé au secteur ou au projet. Celui-ci pourra guider l'équipe dans l'identification des pratiques à améliorer selon le risque de sécurité analysé.

Ensuite, l'équipe peut consulter ce portail de documentation afin de retrouver les guides et les informations les plus récentes pour chaque pratique de sécurité (voir ci-dessous). À noter que le service de sécurité applicative s'efforce d'améliorer cette documentation en continu afin de répondre aux besoins et aux interrogations.

Finalement, la VPSI offre des services d'expert-conseil en sécurité applicative afin de répondre aux besoins plus complexes. Consultez-les ici (https://indall.sharepoint.com/sites/securite/SitePages/Securite-des-applications.aspx).

Les pratiques de sécurité

Pour en savoir plus sur l'une ou l'autre des pratiques, consultez les articles suivants :

- **Gouvernance**
  - A. Normes et conformité
  - B. Formations et conseils (Practices/education-and-guidance.html)
- **Cycle de développement**
  - ***Conception***
    - C. Évaluation des menaces (Practices/threat-assessment.html)
    - D. Exigences de sécurité
    - E. Architecture sécuritaire (Practices/security-architecture.html)
  - ***Implémentation***
    - F. Construction sécuritaire
    - G. Déploiement sécuritaire (Practices/secure-deployment.html)
    - H. Gestion des défauts de sécurité (Practices/defect-management.html)
  - ***Vérification***
    - I. Tests des exigences
    - J. Tests de sécurité (Practices/security-testing.html)
  - ***Opérations***
    - K. Gestion des environnements (Practices/environment-management.md)

Exigences de sécurité

Cadre normatif de sécurité

La Vice-présidence de la Sécurité de l'information s'est récemment dotée d'un cadre normatif de sécurité qui inclut des exigences quant à la sécurité des applications. Pour plus d'informations, consultez le Cadre normatif de sécurité (https://indall.sharepoint.com/sites/securite/SitePages/Cadre-normatif.aspx) publié dans le portail de la vitrine de sécurité de l'information.

Deux normes encadrent spécifiquement le cycle de vie des applications chez iA. Pour les consulter, suivre les liens suivants :

- Norme sur le développement sécuritaire (https://indall.sharepoint.com/sites/securite/SitePages/Directives-et-Normes.aspx)
- Norme sur la sécurité des applications (https://indall.sharepoint.com/sites/securite/SitePages/Directives-et-Normes.aspx)

Trousses de développement

En ce qui concerne l'utilisation des trousses de développement, les équipes doivent adopter des pratiques conformes à la norme sur le développement sécuritaire. Ces pratiques comprennent:

```
* S'assurer de l'utilisation d'outils et de services de développement approuvés par la Société
* Effectuer une revue périodique des outils et des services de développement approuvés
* S'assurer d'utiliser des outils et des services de développement à jour
```

Avant d'utiliser une solution ou un outil pour le développement d'un actif, il est recommandé de vérifier son état de conformité à l'aide d'Hopex. Un schéma de l'écosystème est disponible ici (https://ia-docs-devops.azurewebsites.net/fr/Architecture/TechLandscape.html).

Conformité de sécurité

En plus de l'exigence de se conformer aux normes de sécurité iA, certaines loi, règlements et engagements contractuels contiennent des exigences de sécurité pouvant s'appliquer spécifiquement à un projet ou à une solution applicative (développement et/ou intégration). Le responsable d'une solution applicative doit s'assurer que sa solution est conforme à l'ensemble de ces exigences de sécurité. Il est important de les identifier et de les analyser régulièrement au début d'un cycle de développement. Cela est fait avec l'aide d'un conseiller en sécurité et d'un analyste d'affaires.

Pour plus d'informations, consultez :

- Le SharePoint Risques et conformité, Groupe iA (https://indall.sharepoint.com/sites/GIR).
- Le Cadre normatif de sécurité (https://indall.sharepoint.com/sites/securite/SitePages/Cadre-normatif.aspx) publié dans le portail de la vitrine de sécurité de l'information.
- Les Exigences non fonctionnelles (NFRs) corporatives (https://indall.sharepoint.com/:w:/r/sites/vpti-8AE/_layouts/15/Doc.aspx?sourcedoc=%7B5E678479-D673-45FC-B4C4-9B43B713738C%7D&file=iA%20ENFs%20-%20Exigences%20non%20fonctionnelles.docx&action=default&mobileredirect=true) de l'Architecture d'entreprise

Dernière modification de cette page le 11/30/2023 11:41:56 -05:00 (UTC).